

CEHv13 AI Module 6- System Hacking

NOTES BY VIVEK GOSWAMI

Introduction

System Hacking is the process of exploiting vulnerabilities in an operating system to gain unauthorised access, escalate privileges, steal information, or control system resources.

It is a critical phase in penetration testing and ethical hacking used to assess the security posture of target systems.

Hackers typically follow steps including:-

1. Reconnaissance
2. Scanning for vulnerabilities
3. Gaining access
4. Escalating privileges
5. Maintaining access.

Techniques involve password attacks, exploiting software vulnerabilities, and installing backdoors or malware to sustain control. Ethical hackers use system hacking methods under authorisation to uncover and remediate security weaknesses before malicious actors exploit them

Objectives of System Hacking

- Gain access to the target system.
- Escalate privileges for full administrative control.
- Execute malicious or testing payloads.
- Steal sensitive information such as passwords, tokens, and documents.
- Create persistence for long-term access.
- Cover tracks to avoid detection.
- Stenography and Steganalysis
- Active Directory (AD) Attacks

System Hacking Methodology:

- **Primary Attack Methods:**

- Password Cracking: Extract passwords to gain legitimate user access using techniques such as dictionary attacks and rainbow tables, focusing on weak authentication mechanisms.
- Service and Application Exploitation: Exploit vulnerabilities in running services and applications to escalate privileges, targeting OS vulnerabilities and missing patches.
- Malicious Application Deployment: Install backdoors and persistent access tools such as rootkits, remote access trojans, and command & control malware for stealthy long-term access.

Authentication and Password Security:

- **Authentication Factors:**

- Knowledge-Based Authentication: Includes username and password, PIN codes, and security questions.
- Biometric Authentication: Uses fingerprint scanning, retina scanning, voice recognition, and facial recognition.
- Possession-Based Authentication: Involves device authentication (e.g., MAC address filtering), smart cards, and mobile tokens such as smartphone authentication apps.

Secure Password Characteristics

Essential Security Features:

- Case Sensitivity: Use a mix of uppercase and lowercase letters.
- Special Characters: Include symbols and punctuation marks (e.g., !@#\$%^&*).
- Numeric Components: Combine numbers with letters for increased complexity.
- Sufficient Length: Ensure a minimum of 8 characters, but preferably 12 or more for stronger security.
- Pass-Phrases: Use multiple unrelated words to form complex yet memorable passwords.

Password Policy Best Practices:

- Change passwords regularly (every 90–180 days).
- Enable account lockout after several failed login attempts.
- Enforce password complexity requirements.
- Maintain password history to prevent reuse.
- Implement multi-factor authentication (MFA) for enhanced security.

Tools for System Hacking

- Metasploit Framework – Exploitation and post-exploitation framework for various platforms.
- Mimikatz – Tool for credential dumping and privilege escalation by extracting plaintext passwords and hashes.
- CrackMapExec – Tool for remote code execution, lateral movement, and post-exploitation over SMB protocol.
- Netcat – Versatile networking utility used as a backdoor and for establishing remote shells.
- PowerShell Empire – Post-exploitation framework using PowerShell and Python agents, supporting stealthy communications, keyloggers, credential dumping (e.g., Mimikatz), and persistence mechanisms.
- Windows Credential Editor (WCE) – A Tool to dump and replay Windows passwords and authentication tokens.
- ProcDump – Utility for dumping process memory, useful for extracting credentials and analysing running processes.
- Keyloggers – Tools for recording keystrokes to capture passwords and sensitive input

Password Cracking Tools and Techniques

Crack password using John the Ripper
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt

Crack password using Hashcat
hashcat -m 1000 -a 0 hash.txt /usr/share/wordlists/rockyou.txt

Crack password using Hydra
hydra -l username -P /usr/share/wordlists/rockyou.txt target_ip ssh

Crack password using Medusa
medusa -h target_ip -u username -P /usr/share/wordlists/rockyou.txt -M
ssh

Crack password using Aircrack-ng
aircrack-ng -w /usr/share/wordlists/rockyou.txt -b target_bssid
capture_file.cap

Crack password using Hashid
hashid hash.txt

For Windows

Crack password using John the Ripper
Invoke-John.ps1 -Wordlist "C:\Path\To\Wordlist.txt" -HashFile
"C:\Path\To\Hashes.txt"

Crack password using Hashcat
Invoke-Hashcat.ps1 -Mode 1000 -Attack 0 -HashFile "C:\Path\To\Hashes.txt"
-Wordlist "C:\Path\To\Wordlist.txt"

Crack password using Hydra
Invoke-Hydra.ps1 -Username "username" -PasswordList
"C:\Path\To\Wordlist.txt" -TargetIP "target_ip" -Protocol "ssh"

Crack password using Medusa
Invoke-Medusa.ps1 -Host "target_ip" -Username "username" -PasswordList
"C:\Path\To\Wordlist.txt" -Module "ssh"

Crack password using Aircrack-ng
Invoke-Aircrack.ps1 -Wordlist "C:\Path\To\Wordlist.txt" -BSSID "target_bssid"
-CaptureFile "C:\Path\To\CaptureFile.cap"

Crack password using Hashid
Invoke-Hashid.ps1 -HashFile "C:\Path\To\Hashes.txt"

Practical Steps of System Hacking

Step 1: Gaining Access

- Exploit vulnerabilities in SMB, RDP, or other services.
- Use phishing attacks to deliver payloads.
- Apply password guessing or brute force.

Step 2: Privilege Escalation

- Use `whoami /priv` to check current privileges.
- Use Meterpreter's `getsystem` command to elevate to SYSTEM privileges.
- Run Local Exploit Suggester module in Metasploit for relevant local exploits.
- Perform manual User Account Control (UAC) bypass techniques.

Step 3: Executing Applications

- Deploy keyloggers (e.g., `keyscan_start` in Meterpreter).
- Execute remote commands using `shell` or `execute` in Meterpreter.
- Drop and run files on the target system.

Step 4: Maintaining Access

- Create hidden user accounts:

```
net user backdoor pass123 /add
```

```
net localgroup administrators backdoor /add
```

- Set reverse shell persistence in Windows Registry for backdoor access.

Step 5: Clearing Tracks

- Clear Windows event logs to erase evidence:

```
wevtutil cl System
```

```
wevtutil cl Security
```

- Remove dropped payloads and any associated scripts.

Buffer Overflow

A buffer overflow occurs when a program writes more data to a buffer than it can hold, causing the extra data to overwrite adjacent memory locations. This can lead to unexpected behaviour, crashes, or even code execution.

Types of Buffer Overflows:

1. Stack-Based Buffer Overflow: Occurs when the buffer is allocated on the stack, and the overflow overwrites the return address.
2. Heap-Based Buffer Overflow: Occurs when the buffer is allocated on the heap, and the overflow overwrites adjacent heap chunks.
3. Format String Vulnerability: Occurs when the program uses user-controlled input to format a string, allowing an attacker to manipulate the format string.

Steps to Perform a Buffer Overflow:

1. Identify the Vulnerable Program: Look for programs that use unsafe functions like `strcpy`, `strcat`, `gets`, etc.
2. Determine the Offset: Use a pattern creation tool to determine the offset at which the buffer overflow occurs.
3. Control the Instruction Pointer (EIP): Overwrite the return address with a controlled value.
4. Inject Shellcode: Replace the overwritten return address with shellcode that executes arbitrary code.
5. Exploit the Vulnerability: Run the vulnerable program with the crafted input to trigger the buffer overflow.

Common Attack Vectors

- **Exploiting unpatched vulnerabilities**: Attackers target known weaknesses in software and operating systems that have not been updated or patched.
- **Weak or reused passwords**: Using stolen or guessed passwords that are common, simple, or recycled across multiple accounts.
- **Misconfigured file and folder permissions**: Improper access controls on files/folders allow unauthorised users to view or modify sensitive data.

- **Default admin accounts with unchanged credentials:** Attackers exploit default accounts that have default or weak passwords left unchanged after installation.
- **Weak service configurations:** Poorly configured services such as SMB, FTP, and RDP that expose attack surfaces for exploitation.

Advanced System Hacking Techniques

Modern Attack Vectors

- **Living off the Land**
Using legitimate system tools for malicious purposes to evade detection.
PowerShell and WMI abuse in Windows environments.
Bash and system utilities misuse in Linux environments.
- **Fileless Attacks**
Malware and attack methods reside only in memory without writing files to disk.
Registry and WMI persistence techniques.
Process hollowing and DLL injection to hide malicious code.
- **Container and Cloud Exploitation**
Docker container escape techniques to break out of container isolation.
Attacks on Kubernetes clusters targeting misconfigurations or vulnerabilities.
Exploiting cloud service misconfigurations for unauthorised access or data exfiltration.

System Hardening Best Practices

Access Control

- Implement least privilege principles to minimize excess permissions.
- Conduct regular access reviews and deprovision unused accounts.
- Enforce multi-factor authentication (MFA) for all sensitive access points.

Monitoring and Detection

- Deploy Security Information and Event Management (SIEM) solutions to centralize log collection and analysis.
- Use Endpoint Detection and Response (EDR) tools for real-time threat detection on endpoints.
- Analyse network traffic continuously for anomalies and unauthorized activities.

Patch Management

- Apply security patches and updates regularly to operating systems, applications, and firmware.
- Perform periodic vulnerability assessments and remediate discovered weaknesses promptly.
- Maintain configuration management and compliance monitoring to prevent drift and unauthorized changes.

Additional Best Practices

- Remove unnecessary software, services, and drivers to reduce attack surfaces.
- Harden configurations based on security benchmarks like CIS or DISA STIGs.
- Use network segmentation and firewalls to isolate critical systems.
- Enable logging, auditing, and maintain secure backups regularly.

Cybersecurity Terms and Definitions:

Authentication

Process of verifying the identity of users or systems attempting to access computer resources.

Brute Force Attack

Systematic method of trying all possible password combinations until the correct one is found.

Dictionary Attack

Password cracking technique using a predefined list of common passwords and phrases.

Exploitation

Process of taking advantage of system vulnerabilities to gain unauthorized access or control.

Fingerprinting

Technique for identifying system characteristics, services, and versions for targeted attacks.

Privilege Escalation

Process of gaining higher-level permissions than initially granted to compromise system security.

Rainbow Table

Precomputed table of hash values and corresponding passwords used for rapid password cracking.

Rootkit

Malicious software designed to maintain persistent access while hiding its presence on compromised systems.

Salt

Random data added to passwords before hashing to prevent rainbow table attacks.

Zero-Day Exploit

Attack that exploits previously unknown vulnerabilities before security patches are available